

Lista de verificação de controles e conformidade

Para concluir a lista de verificação da avaliação de controles, consulte as informações fornecidas no [relatório de escopo, objetivos e avaliação de riscos](#). Para obter mais detalhes sobre cada controle, incluindo o tipo e a finalidade, consulte o documento [de categorias de controle](#).

Em seguida, selecione “sim” ou “não” para responder à pergunta: *A Botium Toys possui esse controle implementado atualmente?*

Lista de verificação para avaliação de controles

Sim	Não	Controlar
	•	Privilégio Mínimo
•	•	planos de recuperação de desastres
•	•	Políticas de senha
•	•	Separação de funções
•	•	Firewall
•	•	Sistema de detecção de intrusão (IDS)
•	•	Cópias de segurança
•	•	Software antivírus
•	•	Monitoramento, manutenção e intervenção manuais para sistemas legados.
	•	Criptografia
•	•	Sistema de gerenciamento de senhas
•	•	Fechaduras (escritórios, lojas, armazéns)
•	•	Vigilância por circuito fechado de televisão (CFTV)

-
- Detecção/prevenção de incêndios (alarme de incêndio, sistema de sprinklers, etc.)

Para concluir a lista de verificação de conformidade, consulte as informações fornecidas no [relatório de escopo, objetivos e avaliação de riscos](#). Para obter mais detalhes sobre cada regulamentação de conformidade, revise os [controles, as estruturas e](#) a leitura sobre conformidade.

Em seguida, selecione “sim” ou “não” para responder à pergunta: *A Botium Toys segue atualmente essa prática recomendada de conformidade?*

Lista de verificação de conformidade

Padrão de Segurança de Dados da Indústria de Cartões de Pagamento (PCI DSS)

Sim	Não	Melhores práticas
		• Somente usuários autorizados têm acesso às informações de cartão de crédito dos clientes.
•	•	As informações do cartão de crédito são armazenadas, aceitas, processadas e transmitidas internamente, em um ambiente seguro.
•	•	Implementar procedimentos de criptografia de dados para melhorar a segurança dos pontos de contato e dos dados das transações com cartão de crédito.
•	•	Adote políticas seguras de gerenciamento de senhas.

Regulamento Geral de Proteção de Dados (RGPD)

Sim	Não	Melhores práticas
		• Os dados dos clientes da UE são mantidos em sigilo e segurança.
•	•	Existe um plano em vigor para notificar os clientes da UE em até 72

horas caso seus dados sejam comprometidos/ocorresse uma violação de segurança.

-
- Garantir que os dados sejam devidamente classificados e inventariados.
-
- Garantir o cumprimento das políticas, procedimentos e processos de privacidade para documentar e manter os dados adequadamente.

Controles de Sistemas e Organizações (SOC tipo 1, SOC tipo 2)

Sim	Não	Melhores práticas
-----	-----	-------------------

- | | | |
|---|---|---|
| | • | As políticas de acesso do usuário são estabelecidas. |
| • | • | Dados sensíveis (PII/SPII) são confidenciais/privados. |
| • | • | A integridade dos dados garante que os dados sejam consistentes, completos, precisos e tenham sido validados. |
| • | • | Os dados estão disponíveis apenas para indivíduos autorizados a acessá-los. |

Esta seção é *opcional* e pode ser usada para fornecer um resumo das recomendações ao gerente de TI sobre quais controles e/ou melhores práticas de conformidade a Botium Toys precisa implementar, com base no risco que representa caso não sejam implementados em tempo hábil.

Recomendações (opcional): Nesta seção, forneça recomendações relacionadas a controles e/ou necessidades de conformidade que seu gerente de TI possa comunicar às partes interessadas para reduzir os riscos aos ativos e melhorar a postura de segurança da Botium Toys.

